

Banka Hacklenmedi, Tedarik Zinciri Hedef Oldu: U.S. Bank Olayı

“Dördüncü Taraf” Siber Riskini Gündeme Taşdı

22 Ağustos 2026 | Ankara | Melike Özlem BİLGİLİ - Adli Mühendis

ABD’nin büyük bankalarından U.S. Bancorp, bir fidye yazılımı grubunun kendisini hedef aldığı yönündeki iddiaların ardından yaptığı incelemede, olayın bankanın kendi sistemlerinden değil, üçüncü tarafla bağlantılı bir yükleniciyi kapsayan “dördüncü taraf” bir siber olaydan kaynaklandığını açıkladı. Banka sözcüsü Recorded Future News’e, şu aşamada U.S. Bancorp’un sistemlerinin, ağlarının veya veri depolarının ele geçirildiğine ilişkin kanıt bulunmadığını bildirdi. Banka ayrıca ilgili bilgileri kolluk kuvvetleriyle paylaştığını ve soruşturmaya destek verdiğini belirtti.

Olay, fidye yazılımı gruplarının yayımladığı mağdur listelerinin tek başına bir kurumun doğrudan ihlal edildiğini kanıtlamadığını da gösteriyor. LockBit’in U.S. Bancorp adını sızıntı sitesinde yayımlaması üzerine yapılan inceleme, iddianın bankanın kendi ağı yerine hizmet zincirinin daha aşağısındaki bir kuruluşla bağlantılı olduğunu ortaya koydu. Bu nedenle “U.S. Bank hacklendi” veya “bankanın müşteri verileri çalındı” şeklinde kesin bir ifade mevcut doğrulanmış bilgilerle desteklenmiyor.

NEDEN ÖNEMLİ? ÜÇÜNCÜ TARAF YETMİYOR, DÖRDÜNCÜ TARAF DA İNCELENMELİ

Siber güvenlikte üçüncü taraf riski, bir kurumun doğrudan hizmet aldığı tedarikçi veya hizmet sağlayıcıdan doğan riski ifade ediyor. Dördüncü taraf riski ise bu tedarikçinin kendi alt yüklenicileri ve hizmet sağlayıcıları üzerinden oluşabiliyor. Böylece hedef kurumun kendi ağı ihlal edilmese bile adı, verisi veya operasyonu başka bir şirketin güvenlik olayıyla ilişkilendirilebiliyor.

U.S. Bancorp’un kendi kamuya açık risk bildirimleri de üçüncü tarafların operasyonel, teknoloji veya güvenlik sistemlerindeki ihlallerin banka açısından risk yaratabileceğini kabul ediyor. Bankanın iş sürekliliği belgelerinde kritik üçüncü taraf hizmetlerinin kesintiye uğramasına karşı özel müdahale planlarının bulunduğu belirtiliyor. Güncel olay ise bu zincirin bir adım daha aşağısına, yani tedarikçinin tedarikçisine kadar uzanan görünürlüğü önemi somutlaştırıyor.

ADLİ BİLİRKİŞİ DEĞERLENDİRMESİ

Bu tür bir olayda bilirkişi incelemesinin ilk sorusu “hangi kurumun adı sızıntı sitesinde yer aldı?” değil, verinin ve erişimin gerçek kaynağının neresi olduğudur. Ana kurum, doğrudan tedarikçi ve alt yüklenici arasındaki teknik ve sözleşmesel veri akışı ayrı ayrı haritalanmalıdır.

Öncelikle erişim logları, kimlik doğrulama kayıtları, VPN ve uzaktan erişim kayıtları, API bağlantıları, dosya aktarım kayıtları, bulut denetim logları ve tedarikçiler arasındaki entegrasyon noktaları korunmalıdır. İddia edilen sızıntı örnekleri varsa bunların hash değerleri ve metadata bilgileri, kurumların gerçek veri setleriyle kontrollü biçimde karşılaştırılmalıdır. Bir fidye yazılımı grubunun açıklaması tek başına veri aidiyetini, saldırı yolunu veya kusuru kanıtlamaz.

İkinci aşamada şu sorular cevaplanmalıdır: Veri gerçekten U.S. Bancorp’a mı aitti? Veriye hangi kuruluşun sisteminden erişildi? Ana bankanın sistemlerine herhangi bir geçiş gerçekleşti mi? Dördüncü tarafın hangi yetkilerle hangi verilere erişimi vardı? Alt yüklenici kullanımı sözleşme ve güvenlik politikaları kapsamında bildiriliyor ve denetleniyor muydu? Olayın tespitinden sonra erişim anahtarları, token’lar ve kimlik bilgileri zamanında iptal edildi mi?

Sigorta, tazminat veya rücu uyumsuzluğunda da yalnız saldırının varlığı yeterli değildir. Zararın hangi sistemde olduğu, hangi tarafın kontrol alanında gerçekleştiği, veri veya hizmet bağımlılığının sözleşmeyle nasıl dağıtıldığı ve alınması gereken teknik tedbirlerin olay tarihindeki somut koşullarda yerine getirilip getirilmediği ayrıca değerlendirilmelidir. Teknik bilirkişi, ceza veya hukuki sorumluluk konusunda hüküm kurmak yerine olay zincirini, teknik kontrol alanlarını ve doğrulanabilir bulguları ortaya koymalıdır.

KAYNAKLAR

- Recorded Future News / The Record, 21 Ağustos 2026: "U.S. Bank says breach claims related to fourth-party incident." Banka sözcüsünün olayın dördüncü taraf kaynaklı olduğuna, bankanın kendi sistemlerinde ihlal kanıtı bulunmadığına ve kolluk kuvvetlerinin bilgilendirildiğine ilişkin açıklaması.
- U.S. Bancorp, kamuya açık Enterprise Resiliency Program açıklaması: kritik üçüncü taraf hizmetlerine ilişkin kesinti ve iş sürekliliği planları.
- U.S. Bancorp / SEC, 2026 dönemsel risk bildirimleri: U.S. Bancorp'un veya üçüncü tarafların operasyonel, teknoloji ve güvenlik altyapılarındaki ihlallerin kurumsal risk olarak tanımlanması.